ADR-21 — Provedor de captcha

Architecture Decision Record · Projeto Steely · Escola de TI · UniCesumar

Status	☒ Proposto ☐ Aceito ☐ Rejeitado ☐ Substituído pelo ADR-___	**Data**	31/10/2026
Responsável	Pietro Pasqual Silva	**Sprint**	8–9 / 15–17
Participantes	Fabrício Notoya Thomas, Augusto Palma Guglielmi, Thiago Lopes Martins, Pietro Pasqual Silva, Rafael Tudela Rizental		
Vínculos	STY004 · STY002 · RNF-13 · RNF-01 · RF-01 · ADR-05 · ADR-09 · ADR-13 · ADR-17		

1. Contexto

obrigatória

Qual é o problema ou a necessidade? Por que decidir agora? Descreva a situação atual e as restrições (prazo, custo, equipe, stack, LGPD).

O STY004 exige captcha em operações sensíveis (login, cadastro, compra e formulários) e bloqueio temporário da origem após 3 falhas consecutivas no captcha. O STY002 diz que, após 3 tentativas de login malsucedidas, o captcha passa a ser obrigatório; após 5, a conta é bloqueada temporariamente e o titular avisado por e-mail. Se o provedor cair, deve haver um desafio alternativo interno.

Pelo ADR-09, a autenticação é do Supabase Auth (JWT), mas todo fluxo HTTP, inclusive login, cadastro e recuperação, passa obrigatoriamente pelo FastAPI; o cliente não chama o Supabase Auth direto. O captcha nativo do Supabase Auth exige captcha em toda tentativa, o que não permite a regra das 3 falhas. O RNF-13 limita as rotas de autenticação a 5 tentativas a cada 5 minutos. Restrições: custo zero, LGPD, web e Android, prazo 23/11/2026.

O Hardware Captcha (RF-16) não é objeto deste ADR; ele só é reaproveitado como fallback.

2. Direcionadores da decisão

recomendada

Critérios que pesam na escolha: segurança e privacidade, custo (plano gratuito), esforço até 23/11, facilidade de demonstrar na defesa, manutenção.

- Segurança contra força bruta e automação.
- Cumprir a regra das 3 falhas do STY002 e do STY004.
- Privacidade e LGPD: mínimo de dados pessoais enviados a terceiros.
- Custo zero, pouca fricção e acessibilidade (ADR-20).
- Funcionar no web e no app (Expo).
- Fácil de demonstrar: errar a senha 3 vezes e ver o captcha surgir.

3. Opções consideradas

obrigatória

Liste no mínimo duas opções, cada uma com descrição, prós e contras.

Opção A — Cloudflare Turnstile

Descrição

Captcha geralmente invisível; o navegador resolve desafios em segundo plano e o backend valida o token na API siteverify.

Prós

- Gratuito
- Não depende de cookies de rastreamento nem de conta Google
- Quase sem fricção e acessível
- Validação simples no FastAPI

Contras

- No app exige WebView
- Menos controle sobre o tipo de desafio

Opção B — Google reCAPTCHA (v2/v3)

Descrição

Serviço do Google: v2 com caixa "não sou um robô" e imagens; v3 invisível com nota de risco.

Prós

- Muito conhecido e documentado
- v3 dá nota de risco por ação

Contras

- Coleta de dados para o Google pesa na LGPD
- Plano gratuito com limite mensal
- Não é suportado pelo captcha nativo do Supabase Auth

Opção C — hCaptcha

Descrição

Captcha de imagens com foco em privacidade, alternativa direta ao reCAPTCHA.

Prós

- Bom para privacidade
- Plano gratuito
- Suportado pelo Supabase Auth

Contras

- Desafios de imagem frequentes geram fricção
- Barreiras de acessibilidade

ADR-21 — Provedor de captcha

Continuação

4. Decisão

obrigatória

Opção escolhida: ☒ A ☐ B ☐ C. Justifique por que atende melhor aos direcionadores e por que as outras foram descartadas.

Cloudflare Turnstile, validado pelo FastAPI, que intermedeia login, cadastro, recuperação e pedido de código antes de chamar o Supabase Auth.

O Turnstile atende segurança, privacidade e custo com menor fricção. O reCAPTCHA foi descartado pela coleta de dados e pelo limite do plano gratuito; o hCaptcha, pela fricção. O captcha nativo do Supabase Auth fica desligado, porque exigiria captcha em toda tentativa.

Falhas na janela	Comportamento no login
0 a 2	Login normal, sem captcha; mensagem genérica de erro
3 ou 4	Captcha obrigatório; sem token válido o FastAPI responde 403 com `code` `CAPTCHA_REQUIRED` (RFC 9457, ADR-13)
5	Bloqueio temporário da conta (15 min): 429 com `code` `LOGIN_LOCKED` e `Retry-After`; e-mail ao titular

- Rotas `/api/v1/auth/login`, `/signup`, `/recover` e `/otp` no FastAPI; a dependência `verify_turnstile` (Depends) valida o token no siteverify, uso único.
- Contador por e-mail normalizado e por IP no PostgreSQL (ADR-08), janela de 15 minutos; login bem-sucedido zera o contador. O IP vem da mesma `key_func` do `slowapi` (`CF-Connecting-IP` atrás da Cloudflare, ADR-13).
- 3 falhas consecutivas no captcha bloqueiam o IP por 15 minutos (STY004).
- Se o Turnstile não responder, o FastAPI aplica o desafio interno com imagens de controle do Hardware Captcha.
- Eventos de falha, captcha e bloqueio vão para `audit.system_and_access_logs`, particionada por mês e guardada por 12 meses (ADR-05, ADR-16).
- O rate limiting do RNF-13 (5 req/5 min em auth e 2FA, 30 req/min em captcha) fica no middleware `slowapi` do FastAPI (ADR-09, ADR-13) e atua antes do contador.

5. Consequências

obrigatória

Positivas · Negativas ou riscos aceitos · O que muda no código, no banco, na arquitetura e nos diagramas.

Positivas

- Usuário legítimo quase nunca vê captcha; robôs são barrados a partir da 3ª tentativa.
- Sem atalho: como o cliente não fala direto com o Supabase Auth, o contador não pode ser contornado.
- Regra de negócio fica no FastAPI, como define o ADR-09, e testável com pytest.
- O fallback reaproveita o banco de imagens do Hardware Captcha.

Negativas ou riscos aceitos

- Dependência do Turnstile; mitigada pelo fallback interno.
- O `slowapi` conta na memória de cada processo e não segura ataque volumétrico L7; essa parte do RNF-13 fica com o proxy e o WAF da Cloudflare na frente do Render (ADR-13).
- Um atacante pode bloquear a conta de alguém errando a senha 5 vezes; aceito porque o bloqueio é curto e o titular é avisado.
- A Política de Privacidade precisa citar a Cloudflare como operadora.

O que muda

- Backend: router `auth` no FastAPI, dependência `verify_turnstile` e chamada ao Supabase Auth; erros no padrão RFC 9457 (ADR-13).
- Banco: tabela `auth_login_attempts` (email, ip, falhas, captcha_falhas, bloqueado_ate).
- Web: componente `<Captcha>` exibido quando a API responder `CAPTCHA_REQUIRED`; em `LOGIN_LOCKED`, a tela mostra o tempo do `Retry-After`. App: o mesmo widget em `react-native-webview`.
- Ambiente: `TURNSTILE_SITE_KEY` e `TURNSTILE_SECRET_KEY`. Diagramas: sequência do login cliente → FastAPI → Turnstile → Supabase Auth.

6. Validação

recomendada

Como saber se a decisão deu certo? Teste, critério de aceite, métrica ou demonstração que comprova.

- Testes pytest + HTTPX (ADR-17): 2 falhas sem captcha; 3ª retorna 403 `CAPTCHA_REQUIRED`; tentativa sem token é recusada; 5ª retorna 429 `LOGIN_LOCKED` e envia e-mail.
- 3 tokens inválidos seguidos bloqueiam o IP real (`CF-Connecting-IP`), não o IP do proxy; token reutilizado é rejeitado.

- Com o Turnstile desabilitado, o desafio interno aparece e o evento fica em `audit.system_and_access_logs`.
- Demonstração na defesa: errar a senha 3 vezes ao vivo.

7. Plano de implementação

recomendada

Tarefas necessárias, responsáveis e sprint prevista.

Tarefa	Responsável	Sprint
Criar site no painel da Cloudflare e configurar chaves	A definir	A definir
Router auth no FastAPI, verify_turnstile e tabela auth_login_attempts	A definir	A definir
Componente <Captcha> no web e WebView no app	A definir	A definir
Fallback com imagens de controle do Hardware Captcha	A definir	A definir
Testes pytest dos fluxos de 3 e 5 falhas; atualizar Política de Privacidade	A definir	A definir

8. Referências

recomendada

Documentação, artigos, diagramas e outros ADRs.

- Cloudflare Turnstile — developers.cloudflare.com/turnstile
- Turnstile — Server-side validation (documentação Cloudflare)
- Supabase Auth — Enable captcha protection (supabase.com/docs)
- OWASP — Authentication Cheat Sheet
- RFC 9457 — Problem Details for HTTP APIs
- STY002, STY004, RNF-13; ADR-05 (logs), ADR-09 (auth e rate limiting), ADR-13 (erros), ADR-17 (testes)

Histórico de revisões

Versão	Data	Autor	Alteração
1.0	31/10/2026	Pietro Pasqual Silva	Criação do ADR
1.1	31/10/2026	Pietro Pasqual Silva	Alinhamento com as decisões do grupo (FastAPI, Supabase, pg_cron)
1.2	31/10/2026	Pietro Pasqual Silva	Fechamento dos conflitos do alinhamento (Vite, snapshot OpenAPI, RFC 9457, RLS no FastAPI)
1.3	31/10/2026	Pietro Pasqual Silva	Segundo alinhamento: limites do Realtime, slowapi, SECURITY DEFINER e sessão RLS
1.5	31/10/2026	Pietro Pasqual Silva	Alinhamento com os ADR-13 a 17 (codes, camelCase, schema private, Idempotency-Key, tela do leilão)
1.6	01/11/2026	Revisão cruzada do grupo	Padronização do nome 'Fabrício' nos participantes, conforme a revisão cruzada.

ADENDO — ADR-21 · Provedor de captcha

Projeto Steely · Alinhamento final (propostas do Augusto aceitas). Itens do grupo aplicados a este documento.

Cronograma (item 18)

- Janela de entrega (item 18): Sprints 8–9 / 15–17, até 23/11/2026.
- O campo Sprint do cabeçalho passa a registrar essa janela.

Histórico: versão 1.7 — aplicação dos itens 12, 13, 18 e 19 do alinhamento final do grupo. Este adendo registra as decisões de negócio do grupo que afetam este ADR; o texto das seções 1 a 8 permanece como na versão anterior.